

DIGITAL FORENSIC DOSSIER

Security Incident — Workstation KOR-302N

Departing Revit/BIM lead · user **kor\mli** ("Michael Li") · company-owned workstation

PREPARED BY

Ian Lalonde · Ops & IT

DATE

2026-07-10

REVISED

2026-07-14

CLASSIFICATION

Confidential

EVIDENCE PRESERVED

1,273 files · 785 MB

INTEGRITY

SHA-256 + CoC

COLLECTION

Read-only (c\$)

A Executive summary

UPDATE **Status as of 14 July 2026 — access is cut; recovery underway**

READ FIRST

He gave notice on **2026-06-19** (effective 2026-07-31), stating he was “fully committed to helping with the handover... to make sure nothing is left undone.” During the notice period, the workstation record shows: the source folders were emptied and those projects opened from a personal USB the same morning (**July 8**); 169 of ~195 tool DLLs had been run through an obfuscator (F12); an outside VPN tied to an unidentified account was active on the machine for about six weeks; his mailbox was exported (**June 29**); and both browsers' history was cleared (**night of July 9**). Each item is evidenced in the findings below. This dossier makes **no finding on motive** — that is for HR and legal.

Access is now cut. `kor\mli` is **disabled** in Active Directory (verified at the directory) and his **Microsoft 365 sign-in sessions have been revoked** — he is locked out of the network and the cloud (the directory syncs to the M365 tenant via KOR-DC01). On KOR-302N the unauthorized `Superuser` admin account (see F11) is **disabled and preserved**, Tailscale removed, RDP disabled, and the remote-management agent restored. His **physical building access card has been disabled**. Network, cloud, and physical access are all now closed.

Recovery is underway and going well. A portion of his real, un-obfuscated source was recovered from shadow copies; every deployed plugin is preserved and organized; a full accounting is complete (195 files → 78 distinct tools → only ~22 actually used); and a clean, KOR-owned, **version-agnostic replacement foundation (`KOR.RevitTools`) already builds for Revit 2024/2025/2026**. A drafter working session was held 13 July to scope the rebuild, and next steps are moving. **KOR does not depend on his cooperation to move forward.**

Standing & partnership. `kor\mli` is a member of KOR's `Partners` group. The findings above — removal of company source, obfuscation of company tools, and the outside VPN — bear on his standing as a partner. That is for the partners to decide, with advice; this write-up sets out the facts. (Financial detail is in the companion partnership note.)

Our departing Revit/BIM lead is the sole author of roughly **200 custom Revit plugins** the drafting team uses daily. Examination of his company workstation surfaced the following. For about six weeks his KOR machine was joined to an **unauthorized private VPN controlled by an outside, unidentified account**

— `elton.rheek@gmail.com` — a standing, encrypted path into our environment that bypassed our firewall and domain. Alongside it, **KOR's plugin source code was removed from all company systems**, his KOR mailbox was exported to a file, and — the night of July 9 — **both browsers' history was erased**.

The plugins still run, so there is **no immediate disruption to drafting** — but the machine has had an outside connection into our environment, and rebuilding the tooling without his cooperation is a real project (now underway — see the Update above). This dossier separates what is established as fact from what remains unproven. It makes **no** finding about motive — that is for HR and legal. The findings support acting now.

What we found, in plain terms

1 An unauthorized outside VPN, controlled by an unidentified account. MOST SERIOUS

His KOR machine ran **Tailscale** — a private encrypted network that bypasses our firewall and domain — tied not to a KOR account but to a personal Google identity, `elton.rheek@gmail.com`. It bridged his workstation to an off-domain "test" PC and was active late May through July 3. Our research found that address has **no public footprint and appears pseudonymous** — we do not yet know who is behind it. This is a standing, externally-controlled way into our environment.

2 An unauthorized admin account that survives his logout. CRITICAL

A never-expiring local Administrator account ("Superuser") — on **his machine only**, active as recently as **May 2026**, and **confirmed not IT-created** — a privileged login that keeps working even after his normal account is disabled. (Now disabled and preserved; see F11.)

3 The company's remote-management agent was removed from his machine.

The NinjaOne agent — present on every other machine — had been taken off this one, removing IT's remote visibility of the endpoint. (See F11.)

4 Source code removed from company systems.

His source folders were emptied July 8 (Recycle Bin empty → *moved*, not deleted), while Explorer was open to those same projects on a personal USB. Only stale leftovers remain on company systems.

5 **He exported his KOR mailbox.**

A program he wrote produced a **357 MB export** of his `mli@korstructural.com` mail, dated June 29. Tool and file are preserved.

6 **A second remote-access tool.**

TeamViewer is also installed — an independent remote channel, on top of the VPN.

7 **Browser histories cleared.**

Chrome and Edge browsing histories were **cleared** (saved passwords remain); Edge as recently as the night of July 9. His command history also shows stripping a plugin's digital signature.

8 **Personal cloud & external drives.**

A **personal OneDrive** is configured alongside the company one, with frequent use of large (1–2 TB) personal drives over the past two months.

THE RISKS

- Loss of company IP — custom tooling source off our systems
- Data-exfiltration indicators — source to personal media, mailbox export, history wiped
- A standing outside connection into our environment (~6 weeks)

WHERE THIS LEAVES US

- No immediate impact to drafting — plugins keep running
- We hold safe copies of every deployed plugin
- A KOR-owned source baseline can be rebuilt without his cooperation

What to do now — order matters

- 1 **Preserve his mailbox** (litigation hold) and its audit records before touching the account.
- 2 **Cut the outside access** — block Tailscale and TeamViewer at the firewall.
- 3 **Disable his account** and reset the passwords/keys he could reach.
- 4 **Secure the physical evidence** — the USB, the test PC, and a full disk image of the workstation.
- 5 **Loop in the partners and HR** — and get outside advice if they want it.

The initial examination (2026-07-10) was **read-only**; nothing on KOR-302N was altered during collection. **As of 2026-07-14 containment is complete** — `mli` disabled, M365 sessions revoked, the backdoor account and outside-access tooling removed (see the Update above). 785 MB of evidence is preserved with integrity hashes and a chain-of-custody record.

FULL DOSSIER · EVIDENCE-REFERENCED DETAIL

B Scope, method & custody

Collected 2026-07-09 evening through 2026-07-10, read-only over the `\\KOR-302N\c$` administrative share from an authorized IT workstation. No software was installed on KOR-302N and no files there were modified. Everything is preserved with SHA-256 hashes and a chain-of-custody record.

Constraint: the `kor\mli` session was logged on throughout, so files held open by live processes could not be copied — the **registry hives**, **Amcache**, and **SRUM** database. These require an offline disk image and are the top items for the next collection step.

C Timeline — morning of July 8

All times local, machine KOR-302N, user `kor\mli`. The sequence is central to the source-removal timeline (F1–F2).

- **06:25:06**
Working-source folder **###_Business_LWJ** last modified — now **empty**
folder metadata · owner `kor\mli`
- **06:25:37**
675 MB **OneDrive_1** zip in Downloads (project models — inbound, not source)
file + zip inspection
- **06:37:48**
Kingston DataTraveler 3.0 (28.8 GB) USB connected
setupapi.dev.log · Partition/Diagnostic 1006 · serial E0D55E6CBD0FF640995012F0
- **06:38:40**

Explorer open to **###_Business_LWJ** and to **D:\###_LWJ_Break_Thru\...\bin\Debug\net48** (source projects on the USB)

jump list f01b4d95

● **06:42:27**

D: (KINGSTON) opened; **D:\Guid or Uuid.txt** accessed

Recent shortcuts

● **06:53:38**

Second source folder **2026_InBox** last modified — now **empty**

folder metadata

● **07:09:32**

USB disconnected

Partition/Diagnostic

● **07-09 23:39**

Edge browsing history last written — found **empty (cleared)**

Edge History: 0 URLs + 0-byte journal

Broader context: personal Tailscale installed ~2026-05-24, active through July 3; frequent use of large external drives across May–July; the 357 MB mailbox export created June 29.

D Findings

F11 **Unauthorized persistent admin account, plus removed IT monitoring** — unique to his machine

CRITICAL

A never-expiring local Administrator account, Superuser, is present on KOR-302N — password set 2025-08-28, **last logon 2026-05-16**, set never to expire, not IT-sanctioned, and present on **this machine only** (fleet sweep 2026-07-10). Being local and non-expiring, it **keeps working after his domain account is disabled**.

Origin — resolved. An earlier draft left this open in case IT had created it at build time. IT (the Ops lead) confirms it was **not created or used by IT**, and its **logon on 2026-05-16 shows the credential was authenticated ~9 months after it was created** — ruling out a dormant build-time account. On his workstation, with the IT origin excluded, it is an **unauthorized persistent-admin credential attributable to him**.

Forensic note. No user profile exists for the account (`C:\Users\Superuser` is absent), so its logon was **non-interactive** (network/service/credential use), not a desktop session — consistent with a standing credential rather than casual login. The retained Security event log covers only **2026-06-04→07-10**, so the account's creation event and logon sources are not in it; a **full disk image** would recover the SAM (creation date, RID) and archived logs.

Alongside it, the **NinjaOne RMM agent had been removed from KOR-302N** (uninstalled 2026-05-19) while every other machine still runs it — removing IT's remote visibility of the endpoint. With the personal Tailscale VPN (F4), that is a standing outside path *in*, an unauthorized privileged *local* login, and no monitoring to see either.

Environmental, not his: `NT AUTHORITY\INTERACTIVE` in local Administrators and **TeamViewer** appear on roughly half the fleet, including spare machines — a pre-existing image baseline, not his doing.

Status: `Superuser` disabled and preserved, RMM restored, Tailscale removed, RDP disabled, `mli` disabled. Still to do — reset the built-in Administrator password and check other machines he set up.

F12 **Company tools obfuscated with Obfuscator**

CRITICAL

Of the ~195 deployed plugin DLLs, **169 were run through the code obfuscator**

Obfuscator; the obfuscator's configuration and artifacts are present on the machine.

Obfuscation scrambles compiled code (names, control flow, metadata) so it **cannot be decompiled back into usable source**. These are KOR's own tools, built for KOR's use; with the plain source also removed (F1), the obfuscated binaries and the physical USB are the only routes to their source. **Effect on KOR:** the obfuscated tools can be run but not read or edited — they must be rebuilt from observed behavior. The ~26 non-obfuscated DLLs (including the core `RvtLib2025`) were decompiled to a clean baseline (see Recovery). Interpretation of intent is for HR and legal.

F1 **Company source code removed from company systems**

CRITICAL

Working-source folders **###_Business_LWJ** and **2026_InBox** emptied July 8 (owner kor\mli, Recycle Bin empty → a *move*), with Explorer simultaneously open to the same projects on the personal USB (`D:\###_LWJ_Break_Thru\ ... \bin\Debug\net48`). Only 5 stale, un-versioned template repos remain. The `\\KOR-FS01\Drafting` share holds content only — no source.

F2 **Removable-media history**

HIGH

The July 8 device was a **Kingston DataTraveler 3.0, 28.8 GB** (serial `E0D55E6CBD0FF640995012F0`), connected 06:37→07:09. Others across May–July: WD 1 TB (`X0C-00SJG0`), Samsung T7 Shield 2 TB (`D432104Y0SNLN6S`), Patriot 1 TB, Kingston 128 GB (`EE03DA5152E9`).

F3 **Custom mailbox-export tool + PST**

HIGH

`PSTExporterProject` (`PSTExporterGUI.csproj` , `Form1.cs`) is a purpose-built email exporter; `2026-06-29_mli@korstructural.com_Emails.pst` (357 MB) is a resulting mailbox export. His PowerShell history also holds Outlook COM scripts bulk-moving mail into Archive folders. Tool source and PST preserved.

F4 Unauthorized personal mesh-VPN (Tailscale)

CRITICAL

Installed ~05-24, active through 07-03, on a **personal Google account**

`elton.rheek@gmail.com` (tailnet `tailbc55d0.ts.net`). Tailscale creates an encrypted network bypassing the firewall and domain. The tailnet had **only two nodes**: KOR-302N (`100.72.43.71`) and an off-domain "test" PC (`100.87.155.69` , egressing via KOR's own line — on premises, off domain, invisible to management tools). KOR-302N made RDP sessions to it.

F5 Second remote-access product (TeamViewer)

MEDIUM

Installed machine- and user-wide — an independent external access channel. Prefetch confirms `MSTSC` (RDP), `TAILSCALE`, and `WINRAR` (archiver) were run.

F6 Browser history cleared on both browsers

HIGH

Chrome and Edge `History` databases are valid SQLite but contain **zero URLs**, while their saved-login stores remain populated — a pattern consistent with the history having been **cleared** rather than never recorded (Edge `History` last written 07-09 23:39). Clearing removes the record of web uploads, webmail, and cloud activity.

F7 Code-signature removal

MEDIUM

PowerShell history shows `signtool remove /s` and `Remove-AuthenticodeSignature` removing the Authenticode signature from a Graitec Advance PowerPack `Test.dll` (a commercial plugin).

F8 Personal cloud & external sharing

MEDIUM

A **personal OneDrive** profile is configured alongside the business one. Saved browser logins include external **ShareFile** tenants and a non-KOR home router, alongside expected work services (Autodesk, Bluebeam, Procore, Deltek, EGBC, GitHub).

F9 Programs of interest run

CONTEXT

Prefetch confirms **WinRAR** (archiving / data staging), **Visual Studio** (he builds on this machine), **MSTSC** (RDP), **Tailscale**, PowerShell, and Defender. No rclone/7-Zip/Mega/SCP observed.

F10 Plugin & deployment landscape

CONTEXT · RECOVERY

~200 custom DLLs deploy as per-workstation local copies of
`C:\ProgramData\2015_RevitCommands\` (core libs `ML.dll`, `RvtLib2025.dll`; builds targeting Revit 2020–2027). Both machines' full DLL sets are escrowed — ILSpy/dotPeek can recover a source baseline.

E Established vs. unproven

ESTABLISHED (FACT)

- The timeline and device serials
- The emptied source folders (moved, not deleted)
- The mailbox export tool and 357 MB PST
- The Tailscale install, account, peer & RDP sessions
- TeamViewer; the cleared browser histories
- The signtool signature removal
- The obfuscation of 169 company DLLs (Obfuscator)
- The unauthorized `Superuser` admin account (logon 2026-05-16; confirmed not IT-created)
- His membership of the `Partners` group

NOT ESTABLISHED (OPEN)

- Exactly which files were written to the USB
- Motive or intent
- The real identity behind `elton.rheek@gmail.com`

Identity lead — `elton.rheek@gmail.com`

Decoded from the machine: display "Elton Rheek", Google user-ID `6339171258025277`, tailnet `tailbc55d0.ts.net`. Public web search returned no attributable results. **Apollo** returned the

name but an otherwise empty professional record; **Hunter** confirmed a valid, deliverable Gmail with zero public web sources. Assessment: a real Google identity with essentially no public footprint — **likely pseudonymous**; it does not match "Michael Li," but a Gmail alias is trivial to create. **A lead, not a conclusion** — definitive attribution needs legal process to Tailscale and Google.

A note on interpretation: the evidence shows **removal of company property, data handling outside policy, and unauthorized remote access**. Keep the file to those facts — conclusions based on anything else (including national origin) are unsupported and would weaken KOR's position.

F Risk assessment

RISK	SEVERITY	BASIS
Standing privileged access surviving offboarding (unauthorized admin account) + loss of IT monitoring (RMM removed)	Critical	F11
Loss of company IP (all custom Revit source)	Critical	F1, F3
Deliberate defeat of recovery (company tools obfuscated)	Critical	F12
Data exfiltration (source + full mailbox)	Critical	F1, F3, F6
Standing unauthorized remote access	Critical	F4, F5
Inability to rebuild/maintain plugins (<i>mitigated — recovery underway</i>)	High	F10, F12 (partial recovery + rebuild in progress)
Unknown external party with network access	High	F4

G Immediate actions

Sequence matters — preserve before you disable. Full step detail is in the companion Containment Runbook.

Status — 2026-07-14: steps 2–3 are **complete** (account disabled, M365 sessions revoked, Tailscale/RDP closed, RMM restored, Superuser disabled, physical access card disabled). Mailbox preservation (step 1) and securing the USB, test PC, and a disk image of the workstation (step 4) still to do; the partners and HR are looped in (step 5).

- 1 **Preserve mailbox first** — litigation hold on `mli@korstructural.com`; export audit, message trace, and forwarding/inbox rules before touching the account.
- 2 **Cut the standing access** — firewall-block Tailscale (`*.tailscale.com` , UDP 41641) and TeamViewer; then uninstall during examination. Remote execution on the machine is firewalled, so any live `tailscale status` must be run at KOR-302N.
- 3 **Disable & rotate** — disable `kor\mli` (don't delete), revoke M365 sessions/tokens, rotate secrets he could read.
- 4 **Seize / image** — the Kingston USB, the off-domain test PC, and a full disk image of KOR-302N (which also captures the live-locked hives/Amcache/SRUM).
- 5 **Bring in the partners & HR** — and get outside advice if they want it before any next steps.

H Recovery & going forward

Recovery (independent of the employee)

The plugins keep running in production — no drafting outage. Because we hold safe copies of every deployed plugin, we can rebuild a KOR-owned source baseline: decompile the core libraries (`RvtLib2025.dll` , `ML.dll`) and top tools from escrow, commit to a company Git repo, and adopt his documented per-Revit-year build pattern for 2020–2027.

Going forward — detect & prevent a repeat

For this individual, the right move is **contain, not observe** — don't leave a suspected actor active to watch unless law enforcement directs it. For the environment and any successor:

- **Centralized logging** (SIEM + Windows Event Forwarding) so local logs can't be wiped; **Sysmon** for process/network telemetry; audit policy via GPO (process-creation with command line, logon, removable-storage, PnP).
- **PowerShell script-block + transcription logging.**
- **EDR** with behavioral detection and one-click remote isolation.
- **Egress control** — block/alert on unsanctioned tunnels/remote tools (Tailscale, TeamViewer, AnyDesk, ngrok); DNS filtering.
- **Removable-media control** — GPO to block or read-only USB for at-risk roles; USB auditing; DLP.
- **M365** — verify mailbox auditing; alert on large exports/eDiscovery/PST; restrict external auto-forwarding; block Outlook PST export; DLP; Conditional Access.
- **IP governance** — mandatory company Git, no local-only source; restrict local admin; app allow-listing.

→ **Process & policy** — documented leaver checklist; monitoring grounded in a uniformly applied acceptable-use policy on company devices (BC PIPA: reasonable and proportionate).

I Evidence inventory

Preserved at `C:\Escrow\FORENSICS-KOR-302N-2026-07-10\` — 1,273 files, 785 MB, SHA-256 manifest and chain-of-custody record.

CATEGORY	CONTENTS
logs	Windows event logs (Partition/Diagnostic, Kernel-PnP, Ntfs, Security, System)
setupapi	USB device install history
recent	Shortcuts + jump lists (source of the July-8 timeline)
exec	PowerShell history, 397 Prefetch entries
browser	Chrome/Edge History (cleared) + saved-login stores
outlook	Cached mailbox OST + NST (127 MB)
source-Q	PSTExporter source + 357 MB mailbox PST
tailscale	State + 6 weeks of service logs
onedrive / timeline / tasks	Sync settings (incl. Personal), activity timeline, scheduled tasks

Still to collect (offline image): registry hives (shellbags / RDP MRU / USB reg / Run keys), Amcache, SRUM, and the physical USB and test PC.

This is a security and people matter. IT has handled containment, preservation, and recovery (underway); how it's raised with Michael and what happens next is for the partners and HR. The write-up stays to the facts on purpose.